Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.5 / COMPANION WORKBOOK

Addressing and tiered administration

DHCP, admin seats & where privilege may sign in

Build the control plane before the fleet: DHCP with its core relay for the workstation VLAN, three administration seats on two machines in VLAN 60 (the endpoint seat runs as a virtual machine on the server seat), and directory-enforced tier restrictions proven by both successful in-tier sessions and logged out-of-tier denials.

MATERIALS EDITION 1.5 / COURSE 1.5

Updated 13 October 2026 · sbd-tiered-admin

NAME _____ / DATE _____

START HERE / YOUR LEARNING PATH

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Design the tiers and the address plan

02 Build SBD-DHCP01 and the relay

03 Build the administration systems

04 Restrict where privilege can sign in

05 Prove the tiers and the addressing

06 Delta scan and hand off

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

Before you start

This course builds the control plane before the fleet exists: DHCP for the workstation VLAN, and a tiered administration model where privileged sessions only ever start from dedicated hosts. The model's rule is strict — the jump systems administer; they browse nothing, read no mail, and accept no inbound sessions from user space. To save a machine, the three seats run on two: the endpoint seat is a virtual machine on the server seat, the arrangement the Defense Information Systems Agency (DISA) Windows Privileged Access Workstation (PAW) Security Technical Implementation Guide (STIG) allows where workstations are scarce. The Tier 0 seat runs no virtual machines.

Prerequisites

- ☐ Complete course 1.4: the finished two-tier PKI with its publication site and templates, plus course 1.3's OU structure with the Admin OU in place. The network's routing and default-deny segmentation, with its access control list (ACL) register, are already in place.
- ☐ Provision Windows Server hosts for SBD-DHCP01 (10.0.20.10) and the two physical administration seats in VLAN 60, AdminJumpBox01 (.10) and SBD-ADMIN-SRV01 (.20), and plan SBD-ADMIN-PC01 (.30) as a virtual machine on SBD-ADMIN-SRV01 running the Enterprise or Education edition of the Windows client. SBD-ADMIN-SRV01 needs hardware virtualization and an input–output memory management unit (IOMMU); where it is itself a virtual machine, turn on nested virtualization and media access control (MAC) address spoofing for it, and record what your lab can't provide, such as Credential Guard, as a lab limitation.
- ☐ Decide the privileged accounts: separate admin identities per tier, never daily-driver accounts with admin rights.

What this course builds

- Serve the workstation VLAN through an authorized DHCP server and core relay.
- Stand up single-purpose administration seats for each tier in the Admin OU, with the endpoint seat a virtual machine on the server seat.
- Enforce and prove per-tier sign-in restrictions with captured denial evidence.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-DHCP01 — name, address, OS build	
AdminJumpBox01 — name, address, OS build	
SBD-ADMIN-SRV01 — name, address, OS build	
SBD-ADMIN-PC01 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 20 MIN

Design the tiers and the address plan

> **WHY THIS MATTERS** Tiering is one sentence with teeth: credentials that control a tier never touch a less-trusted one. Write that policy against the OU structure, then plan the DHCP scope the fleet will live in — both before any host is built.

In this lesson you will

- Define the tiers and map each to systems, OUs, and admin accounts.
- Assign each tier its admin seat under the Defense Information Systems Agency (DISA) privileged access workstation (PAW) rules.
- Write the credential rule each tier enforces.
- Plan the VLAN 80 DHCP scope, options, and relay.

Follow the build

1. Define three tiers against what exists, using Microsoft's rule: anything that can control a Tier 0 system is Tier 0. Tier 0 is the identity and trust fabric (DCs, both CAs, PKI-MGMT01) plus what controls it — the hypervisor hosts and their console, the core router's management, and the DC-facing parts of the tools that patch, protect, scan, monitor, and back up the DCs. Tier 1 is the member servers; Tier 2 the user endpoints. Map each tier to its OUs: Tier 0 to the Domain Controllers OU plus a new Tier 0 Servers OU for SBD-SUBCA01 and SBD-PKI-MGMT01 (lesson 4 moves them out of the Servers OU), Tier 1 to the Servers OU, and Tier 2 to the Workstations OU.
2. Assign the admin seats under DISA's Windows PAW Security Technical Implementation Guide (STIG): each privileged access workstation serves one tier (V-243445), and the one that manages the domain controllers is reserved for that work (V-243454, high severity). Where workstations are scarce, V-243445 allows one exception: lower-tier admin accounts in a virtual machine on a higher-tier seat, with the higher-tier accounts on the host. This network uses it to run three seats on two machines: AdminJumpBox01 for Tier 0, running no virtual machines, and SBD-ADMIN-SRV01 for Tier 1, which also runs SBD-ADMIN-PC01, the Tier 2 seat, as a virtual machine with its own name and address. Record the STIG differences in the exception record (AdminJumpBox01 manages all of Tier 0, not only the domain controllers; both physical seats run Windows Server where the STIG expects a Windows client, V-243447), and the PAW rules left open, such as smart-card sign-in (V-243457) and application allowlisting (V-243450, V-243451).
3. Write the credential rule per tier: a Tier 0 account signs in only on Tier 0 systems and AdminJumpBox01; Tier 1 admins work on the SBD-ADMIN-SRV01 host; Tier 2 admins only inside the SBD-ADMIN-PC01 virtual machine, never on its host. The audit custodian uses separate accounts and sessions on SBD-ADMIN-SRV01 that ordinary server operators cannot use. Each administrator gets separate per-tier accounts — the daily account holds no admin rights anywhere.
4. Plan the DHCP design: scope 10.0.80.100–199 for the workstation VLAN — 100 addresses, room for the 50 PCs, the test clients, and replacement machines whose old leases have not yet expired — with options for router 10.0.80.1, the two DCs as DNS, and the sbd.test domain; the core router relays VLAN 80 broadcasts to SBD-DHCP01; everything else stays static.

5. Add the register rows this course needs: VLAN 60 to each tier's management ports (rules A01–A04 in Inside the Network), DHCP relay from the core to SBD-DHCP01 (F04), and explicit denies from VLAN 80 into VLAN 60 — user space never initiates toward the admin plane.

Check your result

```
# Capture the design inputs: OU targets and current account separation.
Get-ADOrganizationalUnit -Filter * | Select-Object Name, DistinguishedName
Get-ADGroupMember 'Domain Admins' | Select-Object Name, SamAccountName
```

WHAT SUCCESS LOOKS LIKE The tier map names systems, OUs, admin seats, and accounts per tier, with SBD-ADMIN-PC01 a virtual machine on SBD-ADMIN-SRV01; the exception record holds the seat plan's STIG differences and open PAW items; the DHCP plan is written; and the register has the new permit and deny rows with owners.

Your record

Evidence to keep: Keep the tier access matrix, the seat plan with its STIG rationale and recorded differences, the per-administrator account plan, the DHCP scope design, and the updated register rows.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What is the one-sentence tiering rule?

REMEMBER Three tiers, each with its systems, OU, admin seat, and accounts. The credential rule is written before any host enforces it. DHCP scope, options, relay, and register rows are planned.

Microsoft · Dynamic Host Configuration Protocol (DHCP)

Microsoft · Privileged access workstations and the access model

Microsoft · Tier model for Active Directory Domain Services

DISA · STIGs Document Library (Windows PAW STIG)

NIST · SP 800-53 Rev. 5 security controls

© 2026 Secure By Design Team LLC.

LESSON 02 / ABOUT 25 MIN

Build SBD-DHCP01 and the relay

> **WHY THIS MATTERS** Addressing is the first service fifty machines will ask for. Build the DHCP server, authorize it in the directory so rogue servers stand out, and relay VLAN 80's broadcasts through the core.

In this lesson you will

- Install and authorize the DHCP role on SBD-DHCP01.
- Create the VLAN 80 scope with the planned options.
- Configure the core relay and prove a lease end to end.

Follow the build

1. Install the DHCP role on SBD-DHCP01 in the Servers OU and complete directory authorization — an unauthorized Windows DHCP server refuses to serve domain networks, the directory's built-in check against rogue DHCP servers.
2. Create the IPv4 scope 10.0.80.100–199 with the planned options: router 10.0.80.1, DNS 10.0.10.10 and 10.0.10.11, domain sbd.test. Leave every other VLAN static as designed.
3. Configure dynamic DNS updates using a dedicated low-privilege credential so client records register securely in the sbd.test zone from course 1.2.
4. Enable the DHCP relay on the core router's VLAN 80 interface toward 10.0.20.10, confirm the register row (F04) permits it, then pull a lease with a temporary test VM in VLAN 80 and watch its A record appear.

Check your result

```
Get-DhcpServerInDC
Get-DhcpServerv4Scope | Select-Object ScopeId, StartRange, EndRange, State
Get-DhcpServerv4OptionValue -ScopeId 10.0.80.0 | Select-Object OptionId, Value
Resolve-DnsName sbd-test80.sbd.test
```

> **WHAT SUCCESS LOOKS LIKE** The server shows as authorized, the scope serves the planned range and options through the relay, and the test client's secure dynamic DNS record exists on both DCs.

Your record

Evidence to keep: Record the authorization output, scope and option configuration, the relay setting on the core, and the test lease with its DNS registration.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

What does directory authorization of a DHCP server give you?

REMEMBER SBD-DHCP01 is authorized, scoped, and serving through the relay. Options hand out the gateway, both DCs, and the domain. A test lease proved addressing and secure DNS registration together.

Microsoft · Dynamic Host Configuration Protocol (DHCP)

Microsoft · Configure a firewall for Active Directory domains

LESSON 03 / ABOUT 50 MIN

Build the administration systems

WHY THIS MATTERS Privileged work gets dedicated, hardened seats: a Tier 0 jump host that runs no virtual machines, and a server-administration seat that also runs the endpoint seat as a virtual machine. Each seat sits in the Admin OU, does nothing but administer, and is maintained by its own group.

In this lesson you will

- Link the hardening policies to the Admin OU's computer sub-OUs, then build the two seats and the seat virtual machine into them.
- Give every seat its own Group Policy object (GPO) and maintenance group.
- Run SBD-ADMIN-PC01 as a virtual machine on SBD-ADMIN-SRV01 with its own name and address, and close the channels that share data between host and guest.
- Keep them single-purpose: hardened, minimal, no user-space services.
- Register and restrict their management paths.

Follow the build

1. Create two computer sub-OUs under the Admin OU — Admin Servers for AdminJumpBox01 and SBD-ADMIN-SRV01, Admin Workstations for the SBD-ADMIN-PC01 virtual machine — and link course 1.3's Security Technical Implementation Guide (STIG) Group Policy objects (GPOs) to them before any seat joins: the member-server policies to Admin Servers and the Windows client policies from the same package to Admin Workstations. Course 1.3 linked them only to the Domain Controllers and Servers OUs, so without this step the seats would boot unhardened.
2. Build AdminJumpBox01 and SBD-ADMIN-SRV01 as clean Windows Server installs and join both into Admin Servers, so the hardening applies from first boot. AdminJumpBox01 never gets the Hyper-V role or a virtual machine: the seat that manages the domain controllers never hosts a lower tier.
3. Give every seat its own seat GPO, linked above the STIG GPO: one on Admin Workstations for the virtual machine, and two on Admin Servers, each filtered to its seat (deny Apply group policy to the other). Each makes the seat's own maintenance group (SBD PAW Maintenance T0, T1, or T2 in this sample), used for nothing else, the only domain group in its local Administrators, to build and patch it: the PAW STIG gives tier accounts user rights only on their seat (V-243456, V-243462), and no group spans tiers. SBD-ADMIN-SRV01's GPO also adds NT VIRTUAL MACHINE\Virtual Machines (*S-1-5-83-0) to Create symbolic links beside Administrators: Group Policy replaces the right's local value, and without that entry, which the STIG accepts on Hyper-V hosts, the virtual machine won't start. Lesson 4 adds each seat's sign-in rights.
4. Add the Hyper-V role to SBD-ADMIN-SRV01 and create SBD-ADMIN-PC01 as a generation 2 virtual machine with Secure Boot and a virtual Trusted Platform Module (TPM), set to start whenever the host starts. The Windows client needs the TPM, and Credential Guard, which the Windows client STIG requires, runs in a virtual machine only on generation 2 and on a host with an input–output memory management unit (IOMMU). Connect it through an external virtual switch on the seat's VLAN 60 adapter with its own address, 10.0.60.30, install the Enterprise or Education edition of the Windows client, and join it into Admin Workstations. Because it keeps its own name and address, the register's rule for SBD-ADMIN-PC01 (A03) still names it alone, never its host.

5. Close the channels that share data between host and guest: the virtual machine separates the tiers only while they share nothing they don't need. Turn off enhanced session mode on the host, so the console carries only screen, keyboard, and mouse, with no shared clipboard, drives, or devices; keep the Guest Service Interface off, so the host can't copy files in; turn off Key-Value Pair Exchange, which passes data both ways; and add no shared folders. What remains, the basic integration services and PowerShell Direct (which can run commands and copy files either way), needs Hyper-V administrator rights on the host, and PowerShell Direct also needs an account in the guest.
6. Administrators who hold both a Tier 1 and a Tier 2 account open the virtual machine's console from the host: SBD-ADMIN-SRV01's seat GPO puts their Tier 1 accounts in the local Hyper-V Administrators group, the one privileged local group the PAW STIG lets a Hyper-V seat fill (V-243463), so they need no host administrator rights. They sign in on the host with the Tier 1 account and inside the console with the Tier 2 one. One person uses the console at a time and signs out of the virtual machine before closing it: without enhanced session mode, the next person to connect takes over an open desktop. A Tier 2-only administrator needs a seat of their own.
7. Strip them to purpose: no browsing to anything but internal admin interfaces, no mail, no file shares hosted, and the management tools for exactly their tier — Remote Server Administration Tools (RSAT) on the two server seats, endpoint tooling inside the SBD-ADMIN-PC01 virtual machine. SBD-ADMIN-SRV01 runs that one virtual machine and no other.
8. Register the management paths: VLAN 60 to Tier 0 and Tier 1 ports (remote desktop 3389, remote management 5985–5986, AD Web Services 9389 to the domain controllers, SSH 22 for the domain-joined Linux servers) from the specific admin host each tier allows, and the router's management on VLAN 100 from AdminJumpBox01 only. Keep the VLAN 80 → VLAN 60 deny from lesson 1 in force.
9. Require the admin seats' own local firewalls, the virtual machine's included, to accept management inbound from nowhere — sessions originate here, they never terminate here, so neither the host nor its guest can manage the other over the network. On both domain controllers, scope the existing Remote Desktop, Windows Remote Management, and Active Directory Web Services firewall rules to AdminJumpBox01 and VLAN 10: allow rules add up, so a new, narrower rule would not restrict the broad ones already enabled.

Check your result

```
Get-ADComputer -SearchBase 'OU=Admin,OU=SBD,DC=sbd,DC=test' -Filter * | Select-Object
Name, DistinguishedName
Get-GPInheritance -Target 'OU=Admin Servers,OU=Admin,OU=SBD,DC=sbd,DC=test'
Get-GPInheritance -Target 'OU=Admin Workstations,OU=Admin,OU=SBD,DC=sbd,DC=test'
Get-LocalGroupMember Administrators   # each seat: its maintenance group, no tier group
# On SBD-ADMIN-SRV01: its one virtual machine, and what host and guest share.
Get-VM | Select-Object Name, Generation, State, AutomaticStartAction   # Start
(Get-VMFirmware SBD-ADMIN-PC01).SecureBoot; (Get-VMSecurity SBD-ADMIN-PC01).TpmEnabled
Get-VMHost | Select-Object EnableEnhancedSessionMode   # False
Get-VMIntegrationService SBD-ADMIN-PC01 | Select-Object Name, Enabled
Get-LocalGroupMember 'Hyper-V Administrators'   # the console users' Tier 1 accounts
Resolve-DnsName SBD-ADMIN-PC01.sbd.test   # 10.0.60.30
# Inside SBD-ADMIN-PC01: Credential Guard is running when the list includes 1.
$dg = Get-CimInstance Win32_DeviceGuard -Namespace root\Microsoft\Windows\DeviceGuard
$dg.SecurityServicesRunning
# On AdminJumpBox01: Hyper-V stays Available, never Installed.
Get-WindowsFeature Hyper-V | Select-Object Name, InstallState
Test-NetConnection SBD-DC01.sbd.test -Port 5985
gpresult /r /scope:computer
```

WHAT SUCCESS LOOKS LIKE AdminJumpBox01 and SBD-ADMIN-SRV01 sit in Admin Servers and the SBD-ADMIN-PC01 virtual machine in Admin Workstations, with the STIG and seat GPOs applied; each seat's local Administrators holds its maintenance group, no tier group; SBD-ADMIN-SRV01 runs only SBD-ADMIN-PC01 (10.0.60.30, generation 2, Secure Boot on, TPM, Credential Guard, starts with the host) with enhanced session mode, the Guest Service Interface, and Key-Value Pair Exchange off; AdminJumpBox01 has no Hyper-V role; management ports answer from the correct seat per tier; and user space can open no session toward VLAN 60.

Your record

Evidence to keep: Record each seat's build sheet (for the virtual machine: host, generation, address), OU placement, GPO links, gpresult output, local group members, host and guest settings, and register rows.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why do the admin hosts run nothing but administration?

REMEMBER Two seats and a seat virtual machine, hardened from first boot; AdminJumpBox01 runs no virtual machines. Each seat has its own maintenance group; host and guest share no clipboard, drives, or folders. Management flows outward only; VLAN 60 accepts nothing inbound. Every management path is a register row.

Microsoft · Privileged access workstations and the access model

DISA · STIGs Document Library (Windows PAW STIG)

Microsoft · Configure a firewall for Active Directory domains

Microsoft · Manage Hyper-V Integration Services

Microsoft · Hyper-V Virtual Machine Connection

Microsoft · Plan for Hyper-V security in Windows Server

Microsoft · Credential Guard overview

Microsoft · Hyper-V virtual machine creation troubleshooting guidance

© 2026 Secure By Design Team LLC.

LESSON 04 / ABOUT 45 MIN

Restrict where privilege can sign in

> **WHY THIS MATTERS** The tier rule becomes real when the directory refuses the wrong sign-in. Give Tier 0 servers their own OU first, deny privileged logons on lower tiers by policy, protect the highest accounts, and make the refusal something you can show in a log.

In this lesson you will

- Move the Tier 0 member servers into their own OU before any deny policy lands.
- Enforce per-tier sign-in restrictions with Group Policy logon rights — on every admin seat and both sides of the seat virtual machine — and record the one network-logon exception.
- Protect Tier 0 accounts and prove a cross-tier sign-in is denied and logged.

Follow the build

1. Create the Tier 0 Servers OU (OU=Tier 0 Servers,OU=SBD,DC=sbd,DC=test) with deletion protection, link course 1.3's member-server STIG GPOs to it so nothing loses its hardening, and move SBD-SUBCA01 and SBD-PKI-MGMT01 there. Both are Tier 0, and the Servers OU is about to deny Tier 0 sign-ins — left there, they would lock Tier 0 out of its own systems.
2. Create one tier logon GPO for the Servers OU — now Tier 1 only — and one for the Workstations OU, and never link either to the Domain Controllers or Tier 0 Servers OUs. User rights don't merge across GPOs: for each right, the highest-precedence GPO that sets it wins, so each list repeats the entries course 1.3's STIG GPO sets for that right (such as Domain Admins and Enterprise Admins), and the tier GPO links above the STIG GPO. On the Servers OU, give the Tier 0 admin group (SBD Tier 0 Admins in this sample) Deny log on locally, Deny log on through Remote Desktop Services, Deny log on as a batch job, and Deny log on as a service. On the Workstations OU, give both the Tier 0 and Tier 1 groups those four denies plus Deny access to this computer from the network.
3. On the Servers OU, set Deny access to this computer from the network — the Tier 0 group plus the STIG's entries — in a separate GPO that excludes the SBD Tier 0 Console Hosts group through security filtering (deny Apply group policy). Course 1.8 adds SBD-WSUS01 and SBD-EPO01 to that group, so those two keep only the STIG's own setting. From AdminJumpBox01, Tier 0 manages the domain controllers' WSUS update ring and their agent policy in Trellix ePolicy Orchestrator (ePO) through those two consoles, using Tier 0 task accounts outside Domain Admins and Enterprise Admins (which the STIG denies network logon on member servers); a Kerberos network logon leaves no reusable credentials on the server. Record the exception — the two servers, the accounts, the reason, and its owner — in the course 1.3 exception record.
4. Finish the seat GPOs from lesson 3 so each seat admits only its own tier, on both sides of the seat virtual machine. Allow log on locally replaces the STIG's list with Administrators and the seat's own groups: the Tier 0 group on AdminJumpBox01 (every Tier 0 account, Domain Admins and Enterprise Admins members included), the Tier 1 and audit custodian groups on SBD-ADMIN-SRV01, and the Tier 2 group inside SBD-ADMIN-PC01 (V-243452; V-243455 for the seat that manages Active Directory). The four denies plus Deny access to this computer from the network go to the other tiers: Tier 0 and Tier 1 inside the virtual machine, Tier 0 and Tier 2 on SBD-ADMIN-SRV01, Tier 1 and Tier 2 on AdminJumpBox01. The PAW STIG requires the higher-tier denies (V-243453, high severity if a Tier 0 account can sign in). Each deny list repeats the STIG GPO's entries for that right, except that

AdminJumpBox01 leaves Domain Admins and Enterprise Admins out of Deny log on locally, because V-243455 admits them there. Record every STIG value these settings change in the exception record.

5. Add Tier 0 administrators to the Protected Users group so the domain refuses their weaker authentication paths, and note the behavior of the newest Windows Server release that supports this design: RC4 ticket-granting tickets are gone and legacy remote password changes are blocked for protected accounts. Protected Users accounts also cannot be delegated, which keeps the console exception free of reusable credentials.
6. Keep the built-in safety valves: one documented break-glass account, excluded from the deny policies and used at a domain controller's console (the admin seats admit only their own tiers), with its password sealed and its every use alarmed in a later logging course.
7. Record the multifactor decision the model calls for on VLAN 60 — smart card or certificate-based sign-in for privileged accounts is the natural follow-on to course 1.4's templates; write the decision and its target date even if implementation waits.

Check your result

```
Get-ADComputer -SearchBase 'OU=Tier 0 Servers,OU=SBD,DC=sbd,DC=test' -Filter * | Select-
Object Name
Get-ADGroupMember 'Protected Users' | Select-Object Name
# On the Tier 2 test machine: export the effective logon rights and read the deny lines.
secedit /export /mergedpolicy /cfg C:\Evidence\tiered-admin\user-rights.inf /areas
user_rights
Select-String -Path C:\Evidence\tiered-admin\user-rights.inf -Pattern 'SeDeny'
(Get-ADGroup 'SBD Tier 0 Admins').SID.Value   # from an admin seat: this SID must appear
on those lines
# Repeat on each seat as its maintenance account, and read who may sign in there.
Select-String -Path C:\Evidence\tiered-admin\user-rights.inf -Pattern 'SeInteractive'
# After the refused Tier 0 sign-in: event 4625 with status 0xC000015B (logon type not
granted).
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-
Date).AddHours(-1)} | Where-Object Message -match '0xC000015B' | Select-Object
TimeCreated, Id
```

> **WHAT SUCCESS LOOKS LIKE** SBD-SUBCA01 and SBD-PKI-MGMT01 sit in the Tier 0 Servers OU and still accept Tier 0 sign-ins; on a Tier 2 test machine the deny rights list the Tier 0 group's SID, and a Tier 0 sign-in there is refused with Security event 4625 (status 0xC000015B); each admin seat lets only its own groups sign in and denies the other tiers — Tier 0 and Tier 1 inside SBD-ADMIN-PC01, Tier 0 and Tier 2 on SBD-ADMIN-SRV01, Tier 1 and Tier 2 on AdminJumpBox01; the exception record holds the console network-logon exception and the seat GPOs' STIG differences; Protected Users contains the Tier 0 admins; and the break-glass and MFA decisions are written.

Your record

Evidence to keep: Keep the Tier 0 Servers OU move, the logon-rights GPO reports with their links and security filtering, the user-rights exports from the test machine and each seat, the refused sign-in's 4625 event, the exception record entries, the Protected Users membership, and the break-glass and MFA decision records.

RECORD	YOUR OBSERVATION
Host(s) and time collected	

RECORD	YOUR OBSERVATION
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What turns the tier rule from policy into enforcement?

REMEMBER Tier 0 servers have their own OU, so the deny policies never lock Tier 0 out. Lower tiers refuse higher-tier credentials by policy, with events to prove it, and each admin seat admits only its own tier; the console network-logon exception is recorded. Tier 0 accounts sit in Protected Users, backed by the stricter defaults of the newest Windows Server release. Break-glass and MFA are written decisions, not loose ends.

Microsoft · Privileged access workstations and the access model

DISA · STIGs Document Library (Windows PAW STIG)

Microsoft · User Rights Assignment

Microsoft · Administrative tools and logon types

Microsoft · Protected Users security group

Microsoft · secedit /export

Microsoft · 4625(F): An account failed to log on

Microsoft · What's new in Windows Server 2025

LESSON 05 / ABOUT 30 MIN

Prove the tiers and the addressing

WHY THIS MATTERS Run the matrix: every tier's administration works from its seat, every cross-tier attempt fails with an event, and the addressing service behaves exactly as registered.

In this lesson you will

- Verify each tier's management path from its designated seat.
- Capture the denial evidence for out-of-tier attempts, across the seat virtual machine's boundary too.
- Re-prove DHCP, relay, and dynamic DNS under the finished rules.

Follow the build

1. From AdminJumpBox01, manage a DC and SBD-SUBCA01 with a Tier 0 account — the Tier 0 Servers OU kept that access; from SBD-ADMIN-SRV01, manage SBD-DHCP01 with a Tier 1 account; from the SBD-ADMIN-PC01 virtual machine, opened from the host by a Tier 1 account without administrator rights there, manage the VLAN 80 test client with a Tier 2 account. Record each success with its session details, including the target's Security event 4624 (and 4672, which marks a logon that received special privileges).
2. Attempt the forbidden combinations — Tier 0 credentials at the test client, a Tier 1 account inside the SBD-ADMIN-PC01 virtual machine, a Tier 2 account on its host, a session from VLAN 80 toward VLAN 60 — and capture both the refusal the user sees and the record the infrastructure writes: Security event 4625 with status 0xC000015B on the system that refused each sign-in, and the router's deny-log entry for the VLAN 80 session.
3. Prove the virtual machine and its host stay apart: remote management attempts between SBD-ADMIN-PC01 and SBD-ADMIN-SRV01 fail in both directions at the target's firewall (they share VLAN 60, so no router sees them), and the console opens as a basic session, with no clipboard or drive sharing.
4. Renew the test client's lease and confirm options, registration, and the relay still behave with all restrictions active; the control plane must not have broken the service plane.
5. Reconcile the tier access matrix against what you just proved and file it with the register — the two documents together are the admin plane's assessable record.

Check your result

```
Enter-PSSession SBD-DHCP01.sbd.test   # from SBD-ADMIN-SRV01, Tier 1 account
vmconnect.exe localhost SBD-ADMIN-PC01   # same account, not elevated: the console opens
Test-NetConnection SBD-ADMIN-SRV01.sbd.test -Port 5985   # from the guest: must fail
Test-NetConnection SBD-ADMIN-PC01.sbd.test -Port 5985   # from the host: must fail
ipconfig /renew   # on the VLAN 80 test client
# Where a sign-in was refused: last hour's 0xC000015B failures (logon type not granted).
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-
Date).AddHours(-1)} | Where-Object Message -match '0xC000015B' | Select-Object
TimeCreated, Id
```

WHAT SUCCESS LOOKS LIKE Every in-tier path succeeds, every tested out-of-tier path fails with captured evidence — in both directions across the seat virtual machine's boundary too — and DHCP with dynamic DNS still works end to end under the full rule set.

© 2026 Secure By Design Team LLC.

Your record

Evidence to keep: Keep the completed tier matrix with timestamps, the denial captures, the host and guest separation results, and the post-restriction lease and registration proof.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What pairs make the denial evidence complete?

> **REMEMBER** In-tier works, out-of-tier fails — across the seat virtual machine's boundary too — and both are on record. Addressing and registration survived the restrictions. Matrix and register reconcile as one assessable story.

Microsoft · Privileged access workstations and the access model

DISA · STIGs Document Library (Windows PAW STIG)

Microsoft · 4625(F): An account failed to log on

Microsoft · Get-WinEvent

Microsoft · Configure a firewall for Active Directory domains

Microsoft · Use local resources on Hyper-V virtual machine with VMConnect

LESSON 06 / ABOUT 20 MIN

Delta scan and hand off

> **WHY THIS MATTERS** Four new systems joined and the directory's logon policy changed — the cadence fires again. Baseline the newcomers, rescan what changed, and hand the next course a network that can finally be watched from somewhere safe.

In this lesson you will

- Baseline the four new systems and rescan the changed ones.
- Fold the course's decisions into the standing records.
- Write the handoff course 1.6 builds on.

Follow the build

1. Run first baselines on SBD-DHCP01, the two physical seats, and the SBD-ADMIN-PC01 virtual machine with the standard benchmark and tool versions — the Windows client benchmark inside the virtual machine — and rescan SBD-SUBCA01 and SBD-PKI-MGMT01: the move to the Tier 0 Servers OU is their change, and the rescan should show their hardening intact.
2. Add this course's rows to the living records: the deny-logon and Protected Users decisions into the exception record where they interact with STIG values, beside lesson 4's console network-logon exception, and the new permit and deny rows into the register with owners.
3. Confirm the admin hosts appear in the hardening course's quarterly cadence; privileged seats are rescanned first from now on, not last.
4. Write the handoff: administration now has a home, which means the logging course can require that SIEM consoles and collectors are managed only from VLAN 60 — with the DC-facing scopes from the Tier 0 seat and audit retention under the custodian's separate accounts — say so explicitly for course 1.6.

Check your result

```
Get-ChildItem C:\Evidence\tiered-admin -Recurse | Select-Object Name, LastWriteTime
Get-FileHash -Algorithm SHA256 C:\Evidence\tiered-admin\*
```

> **WHAT SUCCESS LOOKS LIKE** Four baselines and the Tier 0 server rescans are filed with attributed deltas, the exception record and register carry the new rows, and the handoff names the logging course's management constraint.

Your record

Evidence to keep: Finish the checklist: scan set, updated records, the tier matrix, and the handoff note.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Which systems are rescanned, not baselined, this time?

REMEMBER Baselines, rescans, and attributed deltas are on file. Exception record and register absorbed the course's decisions. Course 1.6 inherits a managed, addressable network.

NIST · SP 800-53 Rev. 5 security controls

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Design the tiers and the address plan	☐ yes	
02 Build SBD-DHCP01 and the relay	☐ yes	
03 Build the administration systems	☐ yes	
04 Restrict where privilege can sign in	☐ yes	
05 Prove the tiers and the addressing	☐ yes	
06 Delta scan and hand off	☐ yes	

Open items carried forward

Next in the learning path

That completes course 1.5. Course 1.6 builds the logging pipeline — collect, protect, analyze — before the fleet arrives to be watched.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.